Decision Brief: Scaling Remote Farmer

Date: 2026-03-12 | **Audience**: Solo developer, team leads | **Phase**: Compiled

Executive Summary

Remote Farmer should scale via three parallel workstreams — all prototyped and validated: **multi-session** (session-keyed Maps, tested [p003]), **multi-sprint** (sprints/ directory with config pointer, tested [p004]), and **repo cartography** (compiler-generated topic-map manifest in <10ms, tested [p001]). Security hardening (cookie auth, CORS restriction, Referrer-Policy) is implemented [p005], backwards compatibility is verified with 10/10 tests passing [p006], and state persistence has been researched with a clear ~40 LOC implementation path [r039, r042].

Recommendation

Proceed to production integration. All three core workstreams are prototype-validated. Remaining work:

1. **Compiler manifest integration** (~1 hour) — wire `generate-manifest.js` into `wheat-compiler.js` so the topic map auto-updates on every compilation [r011, p001].
2. **State persistence** (~1 hour) — add JSON file snapshots + graceful shutdown signal handlers to prevent state loss on restart [r039, r041, r042].
3. **Named Cloudflare tunnel** — replace quick tunnel with named tunnel for SSE support and stable subdomain [r027, r036]. Alternatively, switch SSE to WebSocket [r036].
4. **Token rotation** — add on-demand token rotation to mitigate leak scenarios [r034].

Total estimated remaining effort: 3–5 hours [r008, r026].

Evidence Summary

Multi-Session (13 claims, tested)

Hook payloads include stable `session_id` UUID as a natural routing key [r001]. SessionStart/SessionEnd lifecycle hooks provide explicit session boundaries [r002]. Architecture uses single server with `Map<session_id, SessionState>` and lazy `getSession(id)` initializer [r003, r004]. Dashboard shows unified feed with session color-coding via hue-from-hash [r005, p002]. Heartbeat timeout (5min) handles crashed

sessions [r007]. Estimated 2–4 hours effort [r008]. **Prototype working** — SessionState class, session-keyed Maps, SSE tagging, pill-bar switcher all implemented [p003].

Key constraint: Lifecycle hooks are command-only, not HTTP — requires curl wrapper [w002]. SessionStart fires on resume/clear/compact, not just new sessions [w001].

Risk: Concurrent permission requests from multiple sessions create approval confusion — mitigated with prominent session labels + colors [r006].

Multi-Sprint (9 claims, tested)

Each sprint lives in `sprints/<slug>/` with own claims.json [r020]. Current sprint pointer in `wheat.config.json` for portability (not symlinks, which break on Windows) [r025]. Dashboard shows collapsible sprint card list [r022]. Server adds `--sprints-dir` with hot-reload via `fs.watchFile` [r021]. Cross-sprint references use `sprint-slug:claim-id` format [r024]. Compiler resolves cross-sprint references without schema changes [r023]. Estimated 3–5 hours effort [r026]. **Prototype working** — sprint scanning, `/api/sprints` endpoint, hot-reload, backwards compatible with `--claims` flag [p004].

Repo Cartography (8 claims, tested)

`wheat-manifest.json` is a topic map (not file tree) — AI searches by concept [r017]. Auto-generated by compiler so it never drifts from source [r011]. Single `Read` call replaces 3–5 Glob/Grep calls [r012]. CLAUDE.md stays behavioral, manifest is structural [r015]. **Generator built** — produces manifest in <10ms, ~5KB [p001].

Urgency: Repo already at 157 files (not the estimated 80) [x001]. The `examples/` directory creates 62 duplicate-named files causing search noise [x002]. Context window pollution — not I/O — is the real cost [x003].

Risk: Manifest can mislead if out of date — compiler-generated approach mitigates but does not eliminate [r014]. Search tools still fall back to Glob/Grep if manifest is missing [r013].

Security (12 claims, tested)

Cloudflare quick tunnels do not support SSE — dashboard falls back to 2s polling [r027]. Quick tunnels are dev-only with 200 concurrent request limit [r028]. Token-in-URL leaks through browser history, Referer headers, proxy logs [r029]. CORS wildcard allows any website to make authenticated API calls [r030]. Full compromise on token leak: approve arbitrary tool executions,

set autonomous mode, inject responses [r031]. The `/api/ask` injection vector allows attackers to respond to pending questions before the real user [r032]. Token brute force is infeasible (2^128 entropy, timingSafeEqual) but no rate limiting exists [r033]. No token rotation — only fix for a leak is full restart [r034]. Token embedded in served HTML via template replacement [r037].

Mitigations implemented [p005]: Cookie-based auth (HttpOnly, SameSite=Strict) with 302-redirect to clean URL, CORS restricted to request origin, Referrer-Policy: no-referrer, X-Content-Type-Options: nosniff.

Recommended next steps: Named tunnel for SSE + OAuth [r036], CSRF tokens for state-changing endpoints [r035].

Compatibility (2 claims, tested)

Zero npm dependencies constraint maintained [d004]. **Backwards compatibility verified** — 10-test automated suite confirms single-session workflow survives all refactors: token auth, cookie auth, /api/state, hook fallback to 'default' session, SSE stream, login page, auth rejection all working [p006].

Performance (6 claims, tested)

Manifest generator runs in <10ms [p001]. Single Read call replaces 3–5 search calls [r012]. Performance scales to 10+ sprints and 500+ claims without degrading [d005]. Current repo at 157 files makes cartography urgent [x001]. Estimated 30% context window reduction via manifest approach [r016].

State Persistence (5 claims, documented)

All server state held in memory with zero persistence — restart loses everything [r038]. State classifies into must-persist (trust levels, rules, activity log) vs ephemeral (pending permissions, SSE connections) [r040]. Recommended: JSON file snapshots using built-in fs module, ~40 LOC [r039]. Graceful shutdown via SIGTERM/SIGINT handlers to flush state and deny pending permissions [r041]. Event sourcing is over-engineered for this scale (<100KB state, <1/sec writes) — start with JSON snapshots [r042].

Tradeoffs and Risks

Risk	Severity	Evidence	Mitigation

Approval confusion with concurrent sessions [r006]	Medium	stated	Session labels + colors
Token-in-URL leakage [r029]	High	web	Cookie auth implemented [p005]
CORS wildcard [r030]	High	documented	Restricted to origin [p005]
Full compromise on token leak [r031]	High	documented	Cookie auth + Referrer-Policy [p005], token rotation TODO
/api/ask injection [r032]	Medium	documented	Pending: CSRF tokens [r035]
SSE broken through quick tunnels [r027]	High	documented	Named tunnel or WebSocket [r036]
No token rotation [r034]	Medium	documented	Planned: on-demand rotation
All state in-memory [r038]	Medium	documented	JSON snapshots recommended [r039]
Manifest can mislead if stale [r014]	Low	documented	Compiler-generated, auto-updates
Symlinks break on Windows [r025]	Low	documented	Config file is canonical

Resolved Conflicts

No unresolved conflicts. The symlink vs. config pointer question [r020 vs r025] was resolved in favor of config file as canonical with symlinks as optional convenience.

Appendix: Claim Inventory

ID	Type	Topic	Evidence	Content (abbreviated)
d001	constraint	multi-session	stated	Must support multiple concurrent sessions in dashboard
d002	constraint	multi-sprint	stated	Dashboard must support viewing/switching multiple sprints
d003	constraint	cartography	stated	Repo must be self-describing for AI models

d004	constraint	compatibility	stated	Zero npm deps, backwards compat
d005	constraint	performance	stated	AI search must be measurably faster with cartography
r001	factual	multi-session	documented	Hook payloads include stable session_id UUID
r002	factual	multi-session	documented	SessionStart/SessionEnd lifecycle hooks exist
r003	recommendation	multi-session	documented	Single-server, session-keyed Map architecture
r004	recommendation	multi-session	documented	Refactor globals to per-session state
r005	recommendation	multi-session	documented	Unified feed with session color-coding
r006	risk	multi-session	stated	Concurrent approval confusion
r007	recommendation	multi-session	documented	5min heartbeat timeout for crashed sessions
r008	estimate	multi-session	stated	2–4 hours estimated effort
r010	factual	cartography	documented	Claude Code uses Glob/Grep/Read — no native index
r011	recommendation	cartography	documented	Auto-generate manifest via compiler
r012	factual	cartography	documented	Single Read replaces 3–5 search calls
r013	risk	cartography	documented	Search tools fall back without manifest
r014	risk	cartography	documented	Stale manifest can mislead
r015	recommendation	cartography	documented	CLAUDE.md behavioral, manifest structural
r016	estimate	performance	documented	30% context window reduction

r017	recommendation	cartography	documented	Topic map, not file tree
r020	recommendation	multi-sprint	documented	sprints/slug/ directory structure
r021	recommendation	multi-sprint	documented	--sprints-dir with hot-reload
r022	recommendation	multi-sprint	documented	Collapsible sprint card list UI
r023	factual	multi-sprint	documented	Compiler resolves cross-sprint references
r024	factual	multi-sprint	documented	sprint-slug:claim-id reference format
r025	risk	multi-sprint	documented	Symlinks break on Windows
r026	estimate	multi-sprint	stated	3–5 hours estimated effort
r027	factual	security	documented	CF quick tunnels don't support SSE
r028	factual	security	documented	Quick tunnels are dev-only, 200 req limit
r029	risk	security	web	Token-in-URL leaks via Referer/history/logs
r030	risk	security	documented	CORS wildcard enables cross-origin attacks
r031	risk	security	documented	Full compromise blast radius on token leak
r032	risk	security	documented	/api/ask injection via /api/decide
r033	factual	security	documented	128-bit token, no rate limiting
r034	risk	security	documented	No token rotation, restart = only fix
r035	recommendation	security	web	Cookie auth + CSRF + CORS restriction
r036	recommendation	security	web	Named tunnel or WebSocket transport
r037	risk	security	documented	Token embedded in served HTML

r038	risk	state-persistence	documented	All state in-memory, zero persistence
r039	recommendation	state-persistence	documented	JSON file snapshots, ~40 LOC
r040	factual	state-persistence	documented	State classification: must-persist vs ephemeral
r041	recommendation	state-persistence	documented	SIGTERM/SIGINT graceful shutdown handlers
r042	estimate	state-persistence	documented	Event sourcing over-engineered; JSON snapshots sufficient
w001	factual	multi-session	documented	SessionStart fires on resume/clear/compact too
w002	risk	multi-session	documented	Lifecycle hooks are command-only, not HTTP
x001	factual	performance	tested	Repo at 157 files, not 80
x002	factual	performance	tested	examples/ creates 62 duplicate-named files
x003	factual	performance	tested	Context window pollution is real cost
p001	factual	cartography	tested	Manifest generator: <10ms, ~5KB
p002	recommendation	multi-session	documented	Multi-session refactor plan
p003	factual	multi-session	tested	Multi-session prototype working
p004	factual	multi-sprint	tested	Multi-sprint prototype working
p005	factual	security	tested	Security hardening implemented
p006	factual	compatibility	tested	10/10 backwards compat tests pass

---

Compilation certificate: sha256:fd11e538f52f8ed1e699e34caa1d93cb31ee4cf5c11c1eca7582582335dd0cee | Compiler: wheat v0.2.0 | Claims: 55 | Compiled: 2026-03-12T08:35:10.988Z